

Auditoría de seguridad y arquitectura — SISMAR

Campo	Valor
Sistema	SISMAR (correspondencia-interna)
Alcance	Revisión estática de código (caja blanca). Sin cambios de código, sin exploits, sin pentest en runtime.
Stack	Next.js 16 App Router, Prisma/PostgreSQL, JWT propio (jose HS256), server actions
Fecha	31 de agosto de 2026
Contexto	Correspondencia institucional (referencias a Clínica FOSCAL). Datos potencialmente personales (Ley 1581 de 2012).
Hallazgos	23 (6 altos, 8 medios, 9 bajos)

Dictamen

La aplicación tiene **controles de superficie razonables** (cabeceras HTTP, bcrypt, cookie httpOnly , whitelist de uploads, guards en server actions), heredados de la auditoría FOSCAL de julio 2026 (SEC-002 a SEC-020).

El riesgo residual dominante es **autorización**: el modelo de agencias y la matriz de permisos **no se aplican en las operaciones reales**. Un usuario autenticado de menor privilegio puede leer y alterar correspondencia de otras dependencias.

Resumen ejecutivo

Severidad	Cantidad	Lectura rápida
Alta	6	Tenancy inexistente, IDOR en mutaciones, catálogos abiertos, JWT no revocable, uploads públicos
Media	8	RBAC cosmética, seed destructivo, MIME de cliente, rate limit en memoria, Host header, CSP, sin bitácora
Baja	9	Cookie path, enums string, tests insuficientes, ops no documentada

Cobertura cualitativa de controles (estimación del auditor, no métrica de runtime):

Capa	Cubierto	Hueco
Autenticación (login / JWT / cookie)	~72 %	~28 %
Autorización real (páginas + IDOR)	~25 %	~75 %
Uploads / XSS / cabeceras	~60 %	~40 %
Trazabilidad / tenancy	~15 %	~85 %

Arquitectura observada

Monolito Next.js App Router. El navegador habla con Caddy; Caddy proxifica a Node en localhost. Autenticación: JWT HS256 en cookie `session`. El middleware protege **páginas**, no `/api`. La mutación de negocio va por server actions. Prisma se llama desde páginas (lectura) y desde actions (escritura). Archivos en disco local. Una sola API route: servir uploads.

Capa	Qué hay	Observación
Entrada	Caddy → Next.js 16	<code>Host</code> / <code>X-Forwarded-Proto</code> usados en redirects. El matcher excluye <code>/api</code> , estáticos e imágenes.
Identidad	JWT en cookie + roles en el token	<code>ADMIN</code> / <code>MENSAJERO</code> / <code>AGENCIA</code> . Matriz <code>Permiso</code> en BD, poco usada. <code>bcryptjs</code> coste 12 en alta; seed usa 10 y <code>123456</code> .
Datos	PostgreSQL vía Prisma	Correspondencia, planillas, recorridos, catálogos. Sin <code>createdBy</code> . Uploads en <code>public/uploads</code> o <code>uploadsDir</code> de <code>EmpresaConfig</code> .

Deuda de diseño (no es un CVE)

Hay dos sistemas de autorización (rol en JWT vs matriz en BD) y dos `requireAdmin` (local en `admin.ts` y el de `auth-guard`). Las páginas leen Prisma directo, sin capa de dominio ni filtro de tenancy. Los consecutivos son timestamp+UUID, no un radicado correlativo de negocio. El correo es un stub.

Eso no es explotable por sí solo, pero explica A-01–A-04: **la autorización no está en el núcleo, está en la UI**.

Registro de hallazgos

Altos

A-01 — Sin aislamiento de datos por agencia en lectura

Área	Autorización
Evidencia	<code>src/app/(dashboard)/page.tsx</code> , <code>reportes/page.tsx</code> , <code>correspondencia/entrante/page.tsx</code> , <code>planillas/page.tsx</code> , <code>planillas/[id]/page.tsx</code> , <code>recorridos/page.tsx</code>

Un usuario `AGENCIA` ve correspondencia, planillas, recorridos y reportes de **todas** las agencias. Solo `/mi-correspondencia` filtra por `agenciaId`. En un entorno hospitalario esto es fuga de información entre dependencias.

A-02 — IDOR: cualquier sesión muta correspondencia ajena

Área	Autorización
Evidencia	<code>src/app/actions/correspondencia.ts</code> (<code>updateMailAction</code>), <code>src/app/actions/recorridos.ts</code> (<code>aprobarCorrespondenciaAction</code> , <code>devolverCorrespondenciaAction</code>)

`updateMailAction` exige sesión, no permiso ni pertenencia. Aprobar y devolver actualizan por `id` numérico. Un mensajero o una agencia puede marcar entregada o devolver piezas de otra unidad.

A-03 — IDOR: ciclo de vida de planillas sin permiso ni dueño

Área	Autorización
Evidencia	<code>src/app/actions/panillas.ts</code> — <code>closePlanillaAction</code> , <code>reopenPlanillaAction</code> , <code>processPlanillaAction</code> , <code>removeCorrespondenciaFromPlanillaAction</code> , <code>uploadPlanillaFirmaAction</code>

Cerrar, reabrir, procesar, retirar ítems y subir firma de planilla solo llaman `requireSession()`. No hay `planillas.gestionar` ni comprobación de agencia. Cualquier sesión altera el flujo operativo.

A-04 — Catálogos mutables por cualquier usuario autenticado

Área	Autorización
Evidencia	<code>src/app/actions/catalogos.ts</code> — ciudades, empresas de mensajería, agencias

`create` / `update` / `delete` usan `requireSession`, no `requireAdmin`. El layout `/admin` oculta la UI; las server actions siguen invocables. Centros de costo y sedes **sí** están protegidos con `requireAdmin`: inconsistencia.

A-05 — JWT no revocable y rol congelado (expiración rolling)

Área	Sesión
Evidencia	<code>src/middleware.ts</code> (re-firma el payload); no hay store de sesión

El middleware copia `role` y `userId` del JWT y los vuelve a firmar 24 h en cada request. Un admin degradado o un usuario borrado conserva privilegios mientras siga activo. No hay `jti` ni lista de revocación; el logout solo borra la cookie local.

A-06 — Imágenes subidas accesibles sin autenticación

Área	Archivos
Evidencia	<code>src/lib/uploads.ts</code> (<code>public/uploads</code>), <code>src/middleware.ts</code> (matcher excluye <code>png / jpg / webp</code>), <code>src/app/api/uploads/route.ts</code>

Si `uploadsDir` no está configurado, los archivos caen en `public/uploads`. El matcher excluye `png|jpg|jpeg|gif|webp`, así que esas URLs no pasan por autenticación. `/api/uploads` exige sesión pero no ACL por objeto: cualquier usuario autenticado lee cualquier archivo.

Medios

M-01 — RBAC granular existe pero no se aplica en páginas

Área	Arquitectura
Evidencia	<code>src/lib/permissions.ts</code> vs <code>layouts</code> y <code>src/components/layout/Sidebar.tsx</code>

Existe `Permiso` / `RoIPermiso` / `UsuarioPermiso` y `hasPermission()`, pero el menú muestra casi todos los módulos a todos los roles. Las páginas de negocio no llaman `requirePermission`. El modelo de autorización real es el rol del JWT, no la matriz.

M-02 — Seed destructivo con contraseña 123456

Área	Operación
Evidencia	<code>prisma/seed.ts</code>

`seed.ts` borra correspondencia, usuarios y catálogos y recrea `admin` / `mensajero` / `gerencia` / `talento` con `bcrypt('123456')`. Existe `prisma/rotate-passwords.ts`, pero un seed accidental en producción es pérdida de datos y credenciales conocidas.

M-03 — Uploads validan MIME declarado por el cliente

Área	Archivos
Evidencia	<code>src/lib/uploads.ts</code> — sin magic bytes

`validateUploadFile` confía en `file.type` del navegador. Un polyglot PDF/HTML o un ejecutable con MIME `image/jpeg` pasa. `INLINE_CONTENT_TYPES` incluye `.gif`, que no está en la whitelist de subida.

M-04 — Rate limit en memoria y por username, no por IP

Área	Autenticación
Evidencia	<code>src/lib/rate-limit.ts</code> , <code>src/app/actions/auth.ts</code> (<code>loginAction</code>)

`Map` en proceso: no sobrevive a varios workers ni a varias instancias. La clave es `login:username` en minúsculas; la consulta a BD es case-sensitive. No hay límite por IP: credential stuffing paralelo con muchos usuarios.

M-05 — Redirect usa Host y X-Forwarded-Proto sin allowlist

Área	Infra
Evidencia	<code>src/middleware.ts</code> — <code>redirectTo()</code>

Las redirecciones se arman con el header `Host` y `X-Forwarded-Proto`. Si Node es alcanzable sin Caddy, o Caddy no pisa `Host`, hay open redirect hacia un dominio atacante.

M-06 — CSP con `unsafe-inline` y CSS de marca sin sanitizar

Área	XSS
Evidencia	<code>next.config.ts</code> , <code>src/components/ThemeInjector.tsx</code>

`script-src` y `style-src` permiten `unsafe-inline`. `ThemeInjector` inyecta `colorPrimary` / `Secondary` / `Accent` en un `<style>` sin validar formato HSL. Un valor con `} </style><script>` es XSS almacenado de alcance global (hoy solo admin puede guardarlo).

M-07 — Sin bitácora ni autoría de operaciones

Área	Cumplimiento
Evidencia	<code>prisma/schema.prisma</code> — <code>Correspondencia</code> , <code>Planilla</code> , <code>Recorrido</code>

`Correspondencia` no tiene `createdBy` ni `updatedBy`. No hay tabla de auditoría. Los "emails" son `console.log`. No hay evidencia forense de quién registró, entregó o devolvió una pieza.

M-08 — Timing oracle en login y sin bloqueo de cuenta

Área	Autenticación
Evidencia	<code>src/app/actions/auth.ts</code> — <code>loginAction</code>

Si el usuario no existe, no se ejecuta `bcrypt.compare`. Eso permite enumerar cuentas por tiempo de respuesta. No hay `lockout` persistente: 5 intentos/minuto y se puede reintentar.

Bajos

B-01 — Cookie de middleware sin `path: /`

Área	Sesión
Evidencia	<code>src/middleware.ts</code> vs <code>SESSION_COOKIE_OPTIONS</code> en <code>src/lib/auth.ts</code>

Login y logout usan `SESSION_COOKIE_OPTIONS` con `path: '/'`. El refresh del middleware no setea `path`. En algunos clientes la cookie puede quedar acotada a una ruta.

B-02 — Roles y estados como `String`, no `enum` de Prisma

Área	Integridad
Evidencia	<code>prisma/schema.prisma</code> — <code>Usuario.role</code> , <code>Correspondencia.estado / tipo / importancia</code>

La BD acepta valores basura. La integridad vive solo en Zod de algunos formularios, no en el modelo.

B-03 — Sin índices ni transacciones en flujos concurrentes

Área	Confiabilidad
Evidencia	<code>generatePlanillaAction</code> ; consultas por <code>estado</code> / <code>agenciaId</code>

`generatePlanillaAction` lee pendientes y luego `updateMany` sin transacción: dos clics concurrentes duplican o pierden ítems. Faltan índices en `estado`, `tipo`, `agenciaId`, `planillaId`.

B-04 — Tests de guards solo comprueban que hay un `await`

Área	Aseguramiento
Evidencia	<code>tests/security/actions-guarded.test.ts</code>

El test pasa si el cuerpo contiene `requireSession`. `catalogos.ts` cumple el test y sigue siendo un agujero de autorización. Falsa sensación de cobertura.

B-05 — Notificaciones por consola; usuarios sin email en alta

Área	Funcional
Evidencia	<code>sendRecorridoEmails</code> , <code>createUserSchema</code>

`createUserSchema` no pide email. `sendRecorridoEmails` itera usuarios con email y no envía nada. El flujo de aviso a agencias no existe en producción.

B-06 — `updateMailAction` sin esquema Zod

Área	Validación
Evidencia	<code>src/app/actions/correspondencia.ts</code>

El alta de correspondencia valida con Zod; la edición acepta asunto, importancia, `agenciaId` y anexos sin esquema. `JSON.parse` de identificadores de anexo no tiene tope de tamaño.

B-07 — README de plantilla; ops (Caddy/PM2) fuera del repo

Área	Operación
Evidencia	<code>README.md</code>

El README es el de `create-next-app`. El despliegue (Caddy, puerto 3002, PM2) está en comentarios de código, no en runbooks versionados.

B-08 — Dependencia `cookie` no usada; archivo `panillas.ts` mal nombrado

Área	Mantenimiento

Evidencia	<code>package.json</code> , <code>src/app/actions/panillas.ts</code>
-----------	--

El paquete `cookie` está en `dependencies` y no se importa. El módulo de planillas se llama `panillas.ts`.

B-09 — Rol `AGENCIA` se puede crear sin `agenciaId`

Área	Integridad
Evidencia	<code>createUserAction</code> / <code>createUserSchema</code>

Se puede crear un usuario `AGENCIA` sin `agencia`. `/mi-correspondencia` muestra un aviso, pero el resto de pantallas le dan visibilidad global (A-01).

Tabla consolidada

ID	Sev.	Hallazgo	Área	Evidencia
A-01	Alta	Sin aislamiento de datos por agencia en lectura	Autorización	dashboard, reportes, correspondencia, planillas, recorridos
A-02	Alta	IDOR: cualquier sesión muta correspondencia ajena	Autorización	<code>updateMailAction</code> , aprobar/devolver
A-03	Alta	IDOR: ciclo de vida de planillas sin permiso ni dueño	Autorización	<code>close/reopen/process/remove/upload</code> firma
A-04	Alta	Catálogos mutables por cualquier usuario autenticado	Autorización	<code>catalogos.ts</code> — ciudades, empresas, agencias
A-05	Alta	JWT no revocable y rol congelado (expiración rolling)	Sesión	<code>middleware.ts</code> ; no hay store de sesión
A-06	Alta	Imágenes subidas accesibles sin autenticación	Archivos	<code>public/uploads</code> + matcher de imágenes
M-01	Media	RBAC granular existe pero no se aplica en páginas	Arquitectura	<code>permissions.ts</code> vs layouts y Sidebar
M-02	Media	Seed destructivo con contraseña 123456	Operación	<code>prisma/seed.ts</code>
M-03	Media	Uploads validan MIME declarado por el cliente	Archivos	<code>lib/uploads.ts</code> — sin magic bytes
M-04	Media	Rate limit en memoria y por username, no por IP	Autenticación	<code>lib/rate-limit.ts</code> , <code>loginAction</code>
M-05	Media	Redirect usa Host y X-Forwarded-Proto sin allowlist	Infra	<code>middleware.ts</code> <code>redirectTo()</code>
M-06	Media	CSP con <code>unsafe-inline</code> y CSS de marca sin sanitizar	XSS	<code>next.config.ts</code> , <code>ThemeInjector.tsx</code>

ID	Sev.	Hallazgo	Área	Evidencia
M-07	Media	Sin bitácora ni autoría de operaciones	Cumplimiento	schema Correspondencia / Planilla / Recorrido
M-08	Media	Timing oracle en login y sin bloqueo de cuenta	Autenticación	loginAction — bcrypt solo si el usuario existe
B-01	Baja	Cookie de middleware sin path: /	Sesión	middleware.ts vs SESSION_COOKIE_OPTIONS
B-02	Baja	Roles y estados como String, no enum de Prisma	Integridad	schema.prisma
B-03	Baja	Sin índices ni transacciones en flujos concurrentes	Confiabilidad	generatePlanillaAction
B-04	Baja	Tests de guards solo comprueban que hay un await	Aseguramiento	actions-guarded.test.ts
B-05	Baja	Notificaciones por consola; usuarios sin email en alta	Funcional	sendRecorridoEmails, createUserSchema
B-06	Baja	updateMailAction sin esquema Zod	Validación	actions/correspondencia.ts
B-07	Baja	README de plantilla; ops fuera del repo	Operación	README.md
B-08	Baja	Dependencia cookie no usada; panillas.ts mal nombrado	Mantenimiento	package.json, actions/panillas.ts
B-09	Baja	Rol AGENCIA se puede crear sin agenciaId	Integridad	createUserAction / createUserSchema

Lo que sí está bien

Controles heredados de la auditoría FOSCAL (julio 2026):

- Cabeceras CSP, HSTS, nosniff, Referrer-Policy, Permissions-Policy.
- Cookie httpOnly + SameSite=Lax + Secure en producción (login/logout).
- jose con algoritmo fijado a HS256. JWT_SECRET obligatoria.
- Política de contraseña (≥ 8, mayúscula, minúscula, número) y generador crypto.randomInt.
- Whitelist PDF/PNG/JPG, tope 10 MB, SVG bloqueado, basename contra path traversal en /api/uploads.
- Zod en alta de correspondencia y de usuarios. Mensaje de login genérico. .env fuera de git.

Hueco de los tests actuales

Hay 13 tests bajo tests/security que congelan remediaciones SEC-002 a SEC-020. Ninguno cubre tenancy, IDOR por id, ni “este guard es el correcto”. actions-guarded.test.ts da verde con requireSession en catálogos de admin.

Recomendación: tests de autorización por rol (AGENCIA no puede `updateMail` de otra agencia; no-admin no puede `createAgencia`).

Prioridad de remediación

Orden	Qué hacer	Cierra
1	Filtro de tenencia en lecturas y mutaciones: <code>agenciaId</code> de sesión para rol AGENCIA; IDs ajenos → 403, no redirect silencioso.	A-01, A-02, A-03
2	<code>requireAdmin</code> (o permiso de catálogo) en ciudades, empresas y agencias. <code>requirePermission</code> en <code>close/reopen/process/ updateMail /aprobar/devolver</code> .	A-04, A-03, A-02, M-01
3	Rol y permisos desde BD en cada request (o TTL corto + invalidación). <code>jti</code> y <code>logout</code> server-side.	A-05
4	Forzar uploads fuera de <code>public/</code> , servir solo por <code>/api/uploads</code> con ACL. Magic bytes. Quitar <code>gif</code> de <code>INLINE</code> si no se sube.	A-06, M-03
5	Rate limit compartido (Redis) por IP+usuario. Dummy <code>bcrypt</code> si el usuario no existe. Lockout.	M-04, M-08
6	Allowlist de Host. Sanitizar HSL. Nonce en CSP. <code>createdBy</code> + tabla <code>audit_log</code> . Quitar <code>123456</code> del seed o impedir seed en prod.	M-05, M-06, M-07, M-02

Alcance y limitaciones

Auditoría de caja blanca sobre el árbol de código. No se ejecutó la app, no se explotó ningún endpoint, no se revisó Caddy/PM2/PostgreSQL en el VPS, ni copias de seguridad, ni cifrado en reposo.

Un pentest autenticado con un usuario `AGENCIA` confirmaría A-01–A-04 en minutos.

La clasificación de severidad está alineada al impacto en confidencialidad e integridad de correspondencia institucional, no a CVSS formal.